

E-ITS Asset and Process Modeling Lifecycle and Validation Rules

See juhend kirjeldab andmebaasi ja teenusekihi (Backend) loogilisi kontrolle, mis määravad ära, millal on lubatud assigneerida E-ITS mooduleid nii äriprotsessidele (*business processes*) kui ka sihtobjektidele/varadele (*assets*), et teostada kaitseala modelleerimist (*scope modeling*).

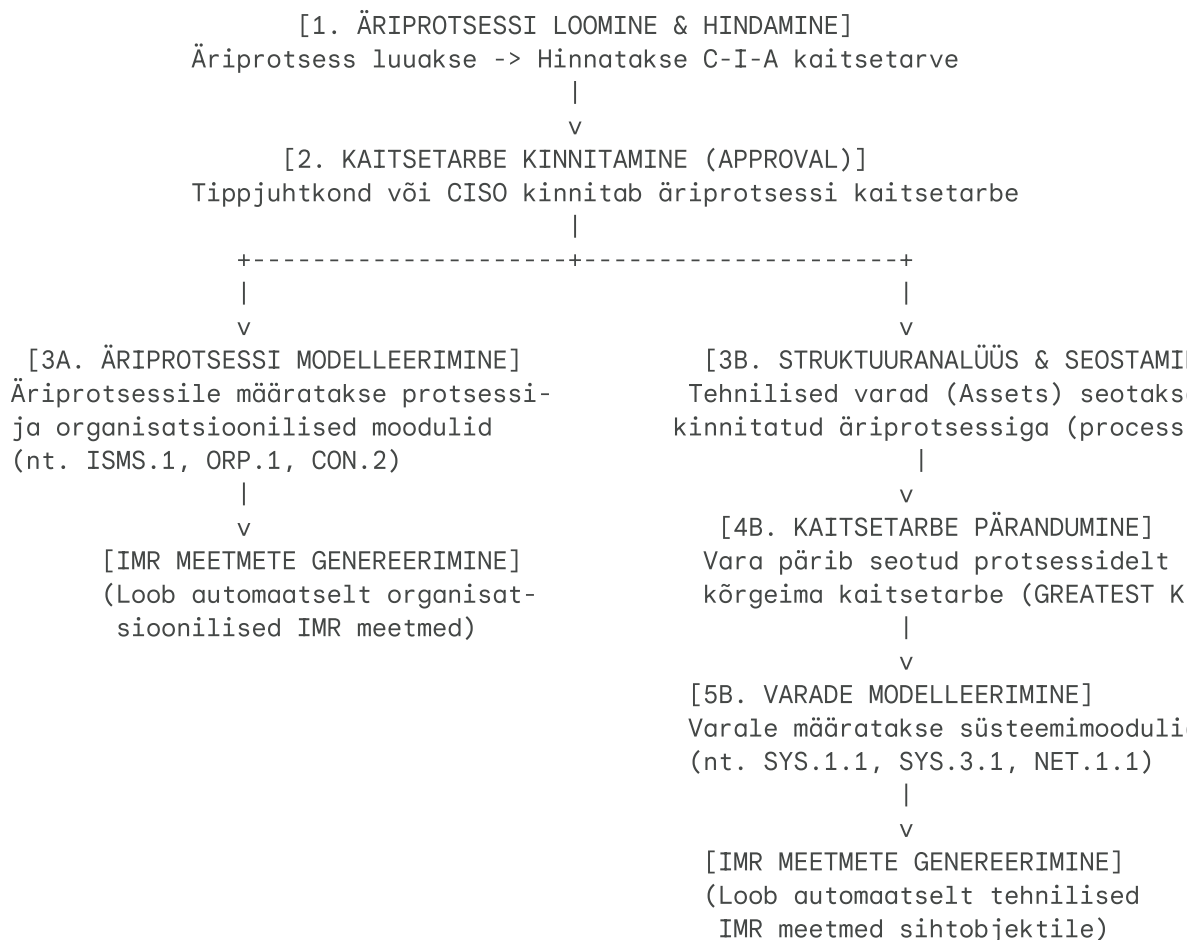
1. E-ITS Terminology Mapping Directory (Sõnastik)

Selleks, et arendusagent kasutaks UI siltidel, API veateadetes ja logides korrektseid termineid, tuleb lähtuda järgmisest sõnastikust:

English Term	Estonian Term (E-ITS)	Database/Code Variable
Information Security Management System (ISMS)	Infoturbe halduse süsteem	isms
Estonian Information Security Standard (E-ITS)	Eesti infoturbestandard	eits
Business Process (BP)	Äriprotsess	business_process / bp
Target Object / Asset	Sihtobjekt / IT-vara	asset
Structural Analysis	Struktuuranalüüs	structural_analysis
Protection Need (C-I-A)	Kaitsetarve (K-T-K: Konfidentsiaalsus, Terviklus, Käideldavus)	protection_need (confidentiality , integrity , availability)
Protection Need Inheritance	Kaitsetarbe pärandumine	protection_need_inheritance
Scope Modeling	Kaitseala modelleerimine	scope_modeling
Mode of Protection	Turbeviis (põhi-, standard-, tuumikuturve)	mode_of_protection (BASELINE , STANDARD , CORE)
Infosec Measures Implementation Plan (IMR)	Infoturbe meetmete rakenduskava (IMR)	imr / imr_items
Security Measure	Turvameede	measure / eits_catalog_measure
Evidence / Proof	Asitõend / Tõendusmaterjal	evidence

2. Logical Step-by-Step Lifecycle (Elutsükkel)

E-ITS on **äriprotsessikeskne standard (äriprotsessikeskne standard)**. Modelleerimine jaguneb kaheks loogiliseks tasandiks: **protsessitasand** (organisatsioonilised ja operatiivsed moodulid) ning **tehniline tasand** (varad ja süsteemid).



3. When CAN Modelling Occur? (Valideerimise kontrollnimekiri)

A. Millal tohib modelleerida ÄRIPROTSESSI?

Äriprotsessile moodulite lisamine (nt ORP.1 personali turvalisus või CON.2 tarkvara kasutamine) on lubatud **AINSALT** siis, kui:

1. **Kaitsetarve on sisestatud:** Äriprotsessil on olemas täidetud konfidentsiaalsuse, tervikluse ja käideldavuse (C-I-A) hinnangud.
2. **Kaitsetarve on kinnitatud:** Protsessi kaitsetarve on ametlikult kinnitatud (approved_by on täidetud) tippjuhtkonna või infoturbejuhi poolt.

B. Millal tohib modelleerida TEHNILIST VARA (Asset)?

Varale tehniliste süsteemimoodulite (nt serverid, võrguseadmed) lisamine on lubatud **AINSALT** siis, kui:

1. **Struktuuranalüüsi seos on loodud:** Vara on tabeli `process_assets` kaudu seotud vähemalt ühe äriprotsessiga.
2. **Kõik seotud äriprotsessid on kinnitatud:** Iga äriprotsess, mida see vara toetab, peab olema läbinud kaitsetarbe hindamise ja see peab olema kinnitatud olekus.

4. Backend Validation SOP (Service Layer Logic)

Sinu OpenCode agent peab teenusekihis `ModelingService.map_module_to_target` enne mooduli sidumist käivitama järgmised valideerimised sõltuvalt sihtobjekti tüübist (`target_type`).

Python / FastAPI valideerimise teenuskood:

```
def validate_process_ready_for_modeling(db: Session, tenant_id: uuid.UUID, process_id: int) -> bool:
    """
    E-ITS reegel: Kontrollib, kas äriprotsessi ennast tohib modelleerida.
    Äriprotsessi kaitsetarve peab olema eelnevalt hindajate poolt kinnitatud.
    """
    summary = db.query(ProtectionNeedSummary).filter(
        ProtectionNeedSummary.business_process_id == process_id,
        ProtectionNeedSummary.tenant_id == tenant_id
    ).first()

    if not summary:
        raise HTTPException(
            status_code=status.HTTP_400_BAD_REQUEST,
            detail="Tõrge: Äriprotsessi ei saa modelleerida, sest selle kaitsetarve ei ole kinnitatud."
        )

    if not summary.approved_by:
        raise HTTPException(
            status_code=status.HTTP_400_BAD_REQUEST,
            detail="Tõrge: Äriprotsessi ei saa modelleerida, sest selle kaitsetarve ei ole heakskiidetud."
        )

    return True


def validate_asset_ready_for_modeling(db: Session, tenant_id: uuid.UUID, asset_id: int) -> bool:
    """
    E-ITS reegel: Kontrollib, kas sihtobjekti (vara) tohib modelleerida.
    Vara peab olema seotud vähemalt ühe äriprotsessiga ja kõigi seotud protsessid peavad olema kinnitatud.
    """
    # 1. Kontrolli seose olemasolu (Struktuuranalüüs)
    process_relations = db.query(ProcessAsset).filter(ProcessAsset.asset_id == asset_id)
    if not process_relations:
        raise HTTPException(
            status_code=status.HTTP_400_BAD_REQUEST,
            detail="Tõrge: Seda vara ei saa modelleerida, sest see on seostamata."
        )

    # 2. Kontrolli kõigi seotud protsesside kaitsetarbe kinnitust
    for relation in process_relations:
        summary = db.query(ProtectionNeedSummary).filter(
            ProtectionNeedSummary.business_process_id == relation.business_process_id,
            ProtectionNeedSummary.tenant_id == tenant_id
        ).first()

        if not summary or not summary.approved_by:
            raise HTTPException(
                status_code=status.HTTP_400_BAD_REQUEST,
                detail=f"Tõrge: Varaga seotud protsess {relation.business_process_id} ei ole kinnitatud."
            )
```

```
        status_code=status.HTTP_400_BAD_REQUEST,  
        detail=f"Tõrge: Seotud äriprotsessi '{relation.business_process.n  
    )  
  
    return True
```

5. Why This Rule Is Critical (Auditing & Compliance Perspective)

- **Väldib metodoloogilist anarhiat (*Kaitseala terviklikkus*):** Kui lubaksime modelleerida protsesse või varasid, mille kaitsetarve on kinnitamata, võidakse rakenduskavasse (IMR) genereerida valed meetmed. Näiteks: kui protsessi kaitsetarve on tegelikult "Suur" (nõuab standardturbe meetmeid), kuid seda muudetakse alles pärast modelleerimist, jääb süsteem auditisse puudulike meetmetega.
- **Auditijälg ja vastutus (*Vastutusahel*):** E-ITS audiitor tuvastab kohe, kui rakenduskava meetmed on genereeritud kinnitamata algandmete pealt. See range valideerimisahel tagab, et organisatsiooni juhtkond võtab ametliku vastutuse kaitsetarbe eest enne, kui IT-meeskond